

Vulnerability Assessment Report for Wiseman Tutoring

Disclaimer

The scan done on this website was a passive scan. No network traffic was modified, and no attacks were performed on the website. The vulnerabilities found were found on publicly accessible information on the Wiseman Tutoring website.

The findings presented in this report are based of common security weaknesses.

Findings

Absence of Anti Cross-Site Request Forgery Tokens (Anti-CSRF Tokens) **[Medium]**

The site's forms don't include a token to verify that form submissions are intentional. This opens the door to Cross-Site Request Forgery attacks, where a malicious site tricks a logged-in user into unknowingly submitting a form on the target site.

Content Security Policy (CSP) **[Medium]**

Header Not Set The server isn't telling browsers which sources of scripts/styles are trusted. Without this, the site is more vulnerable to Cross-Site Scripting (XSS) attacks where an attacker injects malicious scripts.

Missing Anti-Clickjacking Header **[Medium]**

There's no X-Frame-Options or CSP frame-ancestors directive to prevent the site from being embedded in an iframe. Attackers can use this for clickjacking — overlaying an invisible frame to trick users into clicking things they didn't intend to.

Sub Resource Integrity (SRI) **[Medium]**

Attribute Missing External scripts/stylesheets (e.g. from a CDN) are loaded without a hash to verify their integrity. If the CDN is compromised, the site would load the malicious version without knowing.

Open ports which transmit data

unencrypted Port 21, 100, 143 **[Medium]**

Port 21 transmits data in plaintext, which is insecure and if intercepted by an attacker would be easily read.

Port 110 and 143 transmit email credentials in plaintext, which once again would could be exploited by an attacker intercepting network traffic.

Strict-Transport-Security (HSTS) **[Low]**

Header Not Set The site doesn't instruct browsers to always use HTTPS. This could allow downgrade attacks where a connection is intercepted and forced onto HTTP.

X-Content-Type-Options Header Missing

[Low] Without this header, browsers may try to "sniff" the content type of responses, which can lead to MIME-type confusion attacks where a malicious file is executed as a different type.

Remediation steps

Absence of Cross-Site Request Forgery (CSRF) tokens

Remediation: Add CSRF tokens to forms.

Content Security Policy Header (CSP) Header Not Set

Remediation: Add Content-Security-Policy header.

Missing Anti-Clickjacking Header

Remediation: Add X-Frame-Options: DENY.

SRI Missing

Remediation: Add integrity attributes to external scripts.

HSTS Not Set

Remediation: Add Strict-Transport-Security header.

X-Content-Type-Options Missing

Remediation: Add X-Content-Type-Options: nosniff.

Usage of unencrypted ports

Remediation: Close the ports 21, 110, 143. Use Port 22 to replace Port 21 and use Port 993 the secure version of IMAP and Port 995 for the secured version of POP3.